Privacy & security note

What the design collects from an MSME owner, why, where it goes and how long it stays, against India's Digital Personal Data Protection Act 2023 (DPDP). The controls in section 2 are built and tested in the prototype; section 3 lists what production still needs.

Ask only what activation needs
About 5 questions, and no ID numbers in chat.

Consent before documents
A plain notice in the owner's language, one purpose at a time.

Keep documents briefly
Encrypted, then deleted once a decision is made.

AI talks, never decides
Prices come from rules; the LLM never sees documents.

01 Data map

DATA	WHY	WHERE IT GOES	HOW LONG
Chat and business profile type, city, staff, sites, needs, optional GSTIN	Recommend an eligible bundle	Operational store. Chat text goes to the LLM (Gemini) with personal identifiers removed first.	Session lifetime (see production gaps)
KYC documents GST/Udyam certificate, signatory ID, address proof	Verify the business, as telecom rules require	Encrypted vault on our server. Never sent to the LLM or shown to sales and partners.	Deleted when a verdict is reached; at most 7 days if a person must review
Verified details extracted fields, SHA-256 fingerprint of each file	Prove what was checked	Operational store; identifiers masked on every screen	Contract term plus legal retention period
Consent record purposes, notice version, language, time	Evidence of consent and its withdrawal	Consent ledger	As evidence, for as long as the relationship lasts
UPI mandate and lead score	Monthly billing; prioritise follow-up	UPI ID shown masked (`po•••@okbank`); scores visible to staff only	Contract term

02 Controls built into the design

Consent (DPDP §§ 5–6)

- Versioned notice in English or Hindi before any document: what, why, who sees it, how long, rights, grievance contact.
- Separate purposes: KYC is required; WhatsApp updates and marketing start unticked. Without the WhatsApp opt-in, updates stay in the app.
- Withdrawing consent before e-sign deletes the documents at once.

Protection of documents

- Images encrypted at rest (Fernet: AES-128-CBC with HMAC-SHA256) and purged after the decision; only extracted fields and a fingerprint remain.
- Every KYC verdict lists its reasons; unclear cases go to a person rather than being rejected automatically.

Data minimisation

- The advisor never asks for Aadhaar, PAN or bank details. If an owner pastes them, they are stripped (with phone numbers and UPI IDs) before the text reaches the LLM.
- GSTIN is masked wherever it is shown (`27ABC•••••••1Z5`): screens, console free text and the tool results the LLM sees.

Access and accountability

- Role-based console: partners see only the leads routed to them; only sales staff can decide KYC reviews.
- A partner can help in assisted mode only after the owner receives a 4-digit code and chooses to share it.
- Audit log of consent given and withdrawn, uploads, DigiLocker fetches, verification, review decisions, e-sign and assisted access.

Safe use of AI

- The LLM can only call five server-side tools. A guard rejects any reply naming a price or product no tool returned, and the server re-prices every quote, so neither the model nor the browser can set a price. Owner messages are treated as data, not instructions, to limit prompt injection.

03 Prototype shortcuts and what production needs

IN THE PROTOTYPE	FOR PRODUCTION
Console role set by a demo header	Single sign-on with multi-factor authentication; role-based access managed centrally
SQLite file and a local vault key	Managed database encrypted at rest and hosted in India; keys in a key management service with rotation; backups
Gemini on a free-tier key	Paid or enterprise tier whose terms exclude training on prompts, under a data processing agreement
Registries, DigiLocker, e-Sign and UPI mocked	Licensed integrations (GSTN, Udyam, DigiLocker, Aadhaar e-Sign, NPCI UPI Autopay)
Chats kept indefinitely; open CORS	Delete unconverted chats (for example after 90 days); strict origins, TLS, rate limits
No breach or rights process yet	Data Protection Officer, grievance desk, breach notice to the Data Protection Board and affected owners, regular security testing